

Introduction to Linux Privilege Escalation

The root account on Linux systems provides full administrative level access to the operating system. During an assessment, you may gain a low-privileged shell on a Linux host and need to perform privilege escalation to the root account. Fully compromising the host would allow us to capture traffic and access sensitive files, which may be used to further access within the environment. Additionally, if the Linux machine is domain joined, we can gain the NTLM hash and begin enumerating and attacking Active Directory.

Enumeration

Enumeration is the key to privilege escalation. Several helper scripts (such as [LinEnum](#)) exist to assist with enumeration. Still, it is also important to understand what pieces of information to look for and to be able to perform your enumeration manually. When you gain initial shell access to the host, it is important to check several key details.

OS Version: Knowing the distribution (Ubuntu, Debian, FreeBSD, Fedora, SUSE, Red Hat, CentOS, etc.) will give you an idea of the types of tools that may be available. This would also identify the operating system version, for which there may be public exploits available.

Kernel Version: As with the OS version, there may be public exploits that target a vulnerability in a specific kernel version. Kernel exploits can cause system instability or even a complete crash. Be careful running these against any production system, and make sure you fully understand the exploit and possible ramifications before running one.

Running Services: Knowing what services are running on the host is important, especially those running as root. A misconfigured or vulnerable service running as root can be an easy win for privilege escalation. Flaws have been discovered in many common services such as Nagios, Exim, Samba, ProFTPD, etc. Public exploit PoCs exist for many of them, such as CVE-2016-9566, a local privilege escalation flaw in Nagios Core < 4.2.4.

List Current Processes

```
Introduction to Linux Privilege Escalation

dbcyp0n@htb[/htb]$ ps aux | grep root

root      1   1.3  0.1  37656  5664  ?        Ss   23:26   0:01 /sbin/init
root      2   0.0  0.0      0    0  ?        S    23:26   0:00 [kthreadd]
root      3   0.0  0.0      0    0  ?        S    23:26   0:00 [ksoftirqd/0]
root      4   0.0  0.0      0    0  ?        S    23:26   0:00 [kworker/0:0]
root      5   0.0  0.0      0    0  ?        S<   23:26   0:00 [kworker/0:0H]
root      6   0.0  0.0      0    0  ?        S    23:26   0:00 [kworker/u8:0]
root      7   0.0  0.0      0    0  ?        S    23:26   0:00 [rcu_sched]
root      8   0.0  0.0      0    0  ?        S    23:26   0:00 [rcu_bh]
root      9   0.0  0.0      0    0  ?        S    23:26   0:00 [migration/0]

<SNIP>
```

Installed Packages and Versions: Like running services, it is important to check for any out-of-date or vulnerable packages that may be easily leveraged for privilege escalation. An example is Screen, which is a common terminal multiplexer (similar to tmux). It allows you to start a session and open many windows or virtual terminals instead of opening multiple terminal sessions. Screen version 4.05.00 suffers from a privilege escalation vulnerability that can be easily leveraged to escalate privileges.

Logged in Users: Knowing which other users are logged into the system and what they are doing can give greater insight into possible local lateral movement and privilege escalation paths.

lateral movement and privilege escalation paths.

List Current Processes

```

Introduction to Linux Privilege Escalation

dbcypth0n@htb[/htb]$ ps au

USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root          1256  0.0  0.1  65832  3364 tty1    Ss   23:26   0:00 /bin/login --
cliff.moore   1322  0.0  0.1  22600  5160 tty1    S    23:26   0:00 -bash
shared        1367  0.0  0.1  22568  5116 pts/0    Ss   23:27   0:00 -bash
root          1384  0.0  0.1  52700  3812 tty1    S    23:29   0:00 sudo su
root          1385  0.0  0.1  52284  3448 tty1    S    23:29   0:00 su
root          1386  0.0  0.1  21224  3764 tty1    S+   23:29   0:00 bash
shared        1397  0.0  0.1  37364  3428 pts/0    R+   23:30   0:00 ps au

```

User Home Directories: Are other user's home directories accessible? User home folders may also contain SSH keys that can be used to access other systems or scripts and configuration files containing credentials. It is not uncommon to find files containing credentials that can be leveraged to access other systems or even gain entry into the Active Directory environment.

Home Directory Contents

```

Introduction to Linux Privilege Escalation

dbcypth0n@htb[/htb]$ ls /home

backupsvc  bob.jones  cliff.moore  logger  mrb3n  shared  stacey.jenkins

```

We can check individual user directories and check to see if files such as the `.bash_history` file are readable and contain any interesting commands, look for configuration files, and check to see if we can obtain copies of a user's SSH keys.

User's Home Directory Contents

```

Introduction to Linux Privilege Escalation

dbcypth0n@htb[/htb]$ ls -la /home/stacey.jenkins/

total 32
drwxr-xr-x 3 stacey.jenkins stacey.jenkins 4096 Aug 30 23:37 .
drwxr-xr-x 9 root            root            4096 Aug 30 23:33 ..
-rw----- 1 stacey.jenkins stacey.jenkins  41 Aug 30 23:35 .bash_history
-rw-r--r-- 1 stacey.jenkins stacey.jenkins  220 Sep  1  2015 .bash_logout
-rw-r--r-- 1 stacey.jenkins stacey.jenkins 3771 Sep  1  2015 .bashrc
-rw-r--r-- 1 stacey.jenkins stacey.jenkins  97 Aug 30 23:37 config.json
-rw-r--r-- 1 stacey.jenkins stacey.jenkins  655 May 16  2017 .profile
drwx----- 2 stacey.jenkins stacey.jenkins 4096 Aug 30 23:35 .ssh

```

If you find an SSH key for your current user, this could be used to open an SSH session on the host (if SSH is exposed externally) and gain a stable and fully interactive session. SSH keys could be leveraged to access other systems within the network as well. At the minimum, check the ARP cache to see what other hosts are being accessed and cross-reference these against any useable SSH private keys.

SSH Directory Contents

```

Introduction to Linux Privilege Escalation

dbcypth0n@htb[/htb]$ ls -l ~/.ssh

```

```
total 8
-rw----- 1 mrb3n mrb3n 1679 Aug 30 23:37 id_rsa
-rw-r--r-- 1 mrb3n mrb3n 393 Aug 30 23:37 id_rsa.pub
```

It is also important to check a user's bash history, as they may be passing passwords as an argument on the command line, working with git repositories, setting up cron jobs, and more. Reviewing what the user has been doing can give you considerable insight into the type of server you land on and give a hint as to privilege escalation paths.

Bash History

Introduction to Linux Privilege Escalation

```
dbcypth0n@htb[/htb]$ history
 1 id
 2 cd /home/cliff.moore
 3 exit
 4 touch backup.sh
 5 tail /var/log/apache2/error.log
 6 ssh ec2-user@dmz02.inlanefreight.local
 7 history
```

Sudo Privileges: Can the user run any commands either as another user or as root? If you do not have credentials for the user, it may not be possible to leverage sudo permissions. However, often sudoer entries include **NOPASSWD**, meaning that the user can run the specified command without being prompted for a password. Not all commands, even we can run as root, will lead to privilege escalation. It is not uncommon to gain access as a user with full sudo privileges, meaning they can run any command as root. Issuing a simple **sudo su** command will immediately give you a root session.

Sudo - List User's Privileges

Introduction to Linux Privilege Escalation

```
dbcypth0n@htb[/htb]$ sudo -l

Matching Defaults entries for sysadm on NIX02:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/s

User sysadm may run the following commands on NIX02:
    (root) NOPASSWD: /usr/sbin/tcpdump
```

Configuration Files: Configuration files can hold a wealth of information. It is worth searching through all files that end in extensions such as **.conf** and **.config**, for usernames, passwords, and other secrets.

Readable Shadow File: If the shadow file is readable, you will be able to gather password hashes for all users who have a password set. While this does not guarantee further access, these hashes can be subjected to an offline brute-force attack to recover the cleartext password.

Password Hashes in /etc/passwd: Occasionally, you will see password hashes directly in the **/etc/passwd** file. This file is readable by all users, and as with hashes in the **shadow** file, these can be subjected to an offline password cracking attack. This configuration, while not common, can sometimes be seen on embedded devices and routers.

Passwd

Introduction to Linux Privilege Escalation

```
dbcypth0n@htb[/htb]$ cat /etc/passwd
```

```

dbcyph0n@htb[/htb]$ cat /etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
<...SNIP...>
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
sshd:x:110:65534:./var/run/sshd:/usr/sbin/nologin
mrb3n:x:1000:1000:mrb3n,,,:/home/mrb3n:/bin/bash
colord:x:111:118:colord colour management daemon,,,:/var/lib/colord:/bin/false
backupsvc:x:1001:1001:./home/backupsvc:
bob.jones:x:1002:1002:./home/bob.jones:
cliff.moore:x:1003:1003:./home/cliff.moore:
logger:x:1004:1004:./home/logger:
shared:x:1005:1005:./home/shared:
stacey.jenkins:x:1006:1006:./home/stacey.jenkins:
sysadm:$6$vdH7vuQIv6anIBWg$Ysk.UZzI7WxYUBYt8WRIWF0EzWlks0ELDE0HLYinee38QI1A.0HW7WZCrUhZ9wwDz13bPpkTjNuRoUGYhwF

```

Cron Jobs: Cron jobs on Linux systems are similar to Windows scheduled tasks. They are often set up to perform maintenance and backup tasks. In conjunction with other misconfigurations such as relative paths or weak permissions, they can leverage to escalate privileges when the scheduled cron job runs.

Cron Jobs

Introduction to Linux Privilege Escalation	
<pre> dbcyph0n@htb[/htb]\$ ls -la /etc/cron.daily/ total 60 drwxr-xr-x 2 root root 4096 Aug 30 23:49 . drwxr-xr-x 93 root root 4096 Aug 30 23:47 .. -rwxr-xr-x 1 root root 376 Mar 31 2016 apport -rwxr-xr-x 1 root root 1474 Sep 26 2017 apt-compat -rwx--x--x 1 root root 379 Aug 30 23:49 backup -rwxr-xr-x 1 root root 355 May 22 2012 bsdmainutils -rwxr-xr-x 1 root root 1597 Nov 27 2015 dpkg -rwxr-xr-x 1 root root 372 May 6 2015 logrotate -rwxr-xr-x 1 root root 1293 Nov 6 2015 man-db -rwxr-xr-x 1 root root 539 Jul 16 2014 mdadm -rwxr-xr-x 1 root root 435 Nov 18 2014 mlocate -rwxr-xr-x 1 root root 249 Nov 12 2015 passwd -rw-r--r-- 1 root root 102 Apr 5 2016 .placeholder -rwxr-xr-x 1 root root 3449 Feb 26 2016 popularity-contest -rwxr-xr-x 1 root root 214 May 24 2016 update-notifier-common </pre>	

Unmounted File Systems and Additional Drives: If you discover and can mount an additional drive or unmounted file system, you may find sensitive files, passwords, or backups that can be leveraged to escalate privileges.

File Systems & Additional Drives

Introduction to Linux Privilege Escalation	
<pre> dbcyph0n@htb[/htb]\$ lsblk NAME MAJ:MIN RM SIZE RO TYPE MOUNTPOINT sda 8:0 0 30G 0 disk ├─sda1 8:1 0 29G 0 part / ├─sda2 8:2 0 1K 0 part └─sda5 8:5 0 32M 0 part [forward] </pre>	

```

--suas  8:5  0  9/5M  0 part [SWAP]
sr0     11:0  1  848M  0 rom

```

SETUID and SETGID Permissions: Binaries are set with these permissions to allow a user to run a command as root, without having to grant root-level access to the user. Many binaries contain functionality that can be exploited to get a root shell.

Writeable Directories: It is important to discover which directories are writeable if you need to download tools to the system. You may discover a writeable directory where a cron job places files, which provides an idea of how often the cron job runs and could be used to elevate privileges if the script that the cron job runs is also writeable.

Find Writable Directories

Introduction to Linux Privilege Escalation

```

dbcypth0n@htb[/htb]$ find / -path /proc -prune -o -type d -perm -o+w 2>/dev/null

/dmz-backups
/tmp
/tmp/VMwareDnD
/tmp/.XIM-unix
/tmp/.Test-unix
/tmp/.X11-unix
/tmp/systemd-private-8a2c51fcbad240d09578916b47b0bb17-systemd-timesyncd.service-TIecv0/tmp
/tmp/.font-unix
/tmp/.ICE-unix
/proc
/dev/mqueue
/dev/shm
/var/tmp
/var/tmp/systemd-private-8a2c51fcbad240d09578916b47b0bb17-systemd-timesyncd.service-hm6QdL/tmp
/var/crash
/run/lock

```

Writeable Files: Are any scripts or configuration files world-writable? While altering configuration files can be extremely destructive, there may be instances where a minor modification can open up further access. Also, any scripts that are run as root using cron jobs can be modified slightly to append a command.

Find Writable Files

Introduction to Linux Privilege Escalation

```

dbcypth0n@htb[/htb]$ find / -path /proc -prune -o -type f -perm -o+w 2>/dev/null

/etc/cron.daily/backup
/dmz-backups/backup.sh
/proc
/sys/fs/cgroup/memory/init.scope/cgroup.event_control

<SNIP>

/home/backupsvc/backup.sh

<SNIP>

```

Moving on

As we have seen, there are various manual enumeration techniques that we can perform to gain information to inform various privilege escalation attacks. A variety of techniques exist that can be leveraged to perform local privilege escalation on Linux, which we will cover in the next sections.

[Next →](#)

+10 Streak pts

[✔ Mark Complete & Next](#) [Cheat Sheet](#)

Table of Contents

Introduction

[Introduction to Linux Privilege Escalation](#)

Information Gathering

-  Environment Enumeration
-  Linux Services & Internals Enumeration
-  Credential Hunting

Environment-based Privilege Escalation

-  Path Abuse
- Wildcard Abuse
-  Escaping Restricted Shells

Permissions-based Privilege Escalation

-  Special Permissions
-  Sudo Rights Abuse
-  Privileged Groups
-  Capabilities

Service-based Privilege Escalation

-  Vulnerable Services
-  Cron Job Abuse
-  LXD
-  Docker
- Kubernetes
-  Logrotate
-  Miscellaneous Techniques

Linux Internals-based Privilege Escalation

-  Kernel Exploits
-  Shared Libraries
-  Shared Object Hijacking
-  Python Library Hijacking

Recent 0-Days

-  Sudo
-  Polkit

 Dirty Pipe

Netfilter

Hardening Considerations

Linux Hardening

Skills Assessment

 Linux Local Privilege Escalation - Skills Assessment

My Workstation

OFFLINE

 Start Instance

 / 1 spawns left